

SECURITY POSTURE ASSESSMENT

Microsoft Defender - Secure Score Analysis & Improvement

M365 Security Portfolio – Project 4

Prepared by	Kapil Chaudhary - GRC & Cybersecurity Professional
Date	September 2026
Platform	Microsoft Defender XDR (M365 E5 Trial Environment)
Framework Alignment	ISO 27001:2022, SOC 2, PCI DSS, NIST CSF
Prerequisites	Project 1 (Entra ID), Project 2 (Intune), Project 3 (Purview) - Completed
GitHub	github.com/ethicalkaps

Executive Summary

This document presents a Security Posture Assessment conducted using Microsoft Defender's Secure Score framework within a Microsoft 365 E5 environment. The assessment establishes a baseline security score, identifies prioritized improvement opportunities, implements quick-win remediation actions, and documents the measurable improvement achieved - demonstrating the continuous improvement cycle that compliance frameworks like ISO 27001 Clause 10 require.

Microsoft Secure Score is an automated security posture assessment tool that evaluates an organization's security configuration across identity, devices, apps, and data - producing a numerical score with prioritized recommendations for improvement. This is the same tool enterprise security teams use to track and improve their compliance posture continuously, making it directly relevant to GRC analyst roles that require security monitoring, control effectiveness measurement, and compliance reporting.

This project completes the four-project Microsoft Security Portfolio, capping the security architecture chain: Identity (Entra ID) → Endpoint (Intune) → Data (Purview) → Posture Assessment (Defender). Together, these four projects demonstrate end-to-end enterprise security implementation, monitoring, and continuous improvement capability.

All configurations were performed in a personal M365 E5 trial environment for portfolio demonstration purposes. No production systems or employer data were used.

Compliance Mapping Overview

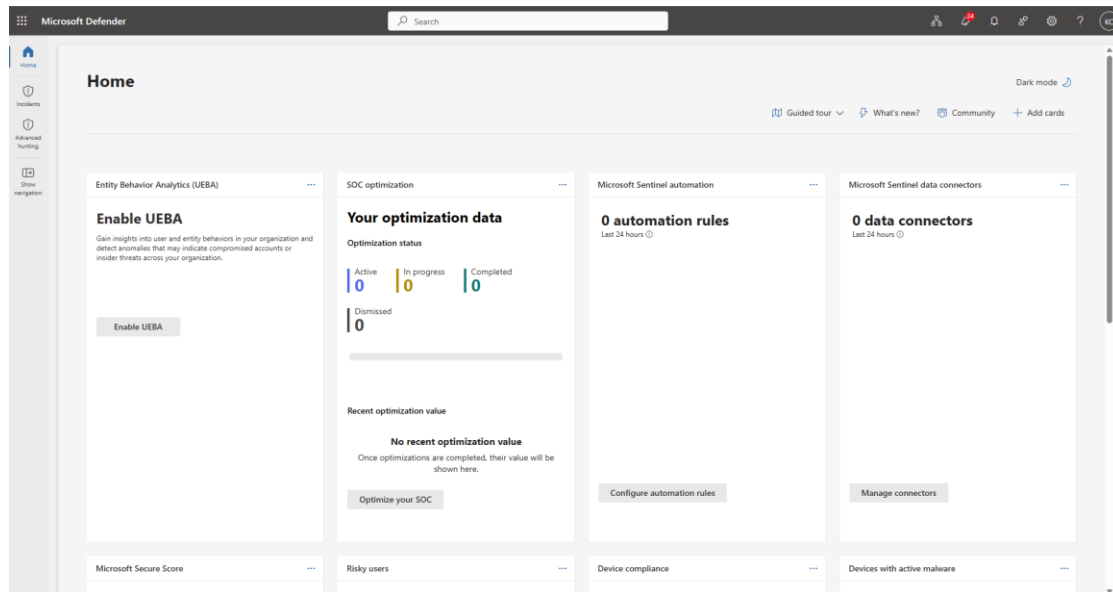
Assessment Activity	ISO 27001 Control	SOC 2 / PCI DSS / NIST CSF
Secure Score baseline assessment	A.18.2.1 - Independent review of information security	SOC 2 CC4.1 / PCI DSS Req 11 / NIST CSF Identify
Recommended actions review	A.18.2.1 - Independent review	SOC 2 CC4.1 / NIST CSF Identify
Quick-win remediation (MFA)	A.9.4.2 - Secure log-on procedures	SOC 2 CC6.1 / PCI DSS Req 8 / NIST CSF Protect
Before/after score comparison	Clause 10 - Continual improvement	SOC 2 CC4.1 / PCI DSS Req 11 / NIST CSF Identify
Incident and alert monitoring	A.16.1.2 - Reporting security events	SOC 2 CC7.2 / PCI DSS Req 10 / NIST CSF Detect
Threat analytics review	A.5.7 - Threat intelligence	SOC 2 CC7.2 / NIST CSF Detect
Security reporting	A.18.2.1 - Independent review	SOC 2 CC4.1 / PCI DSS Req 11 / NIST CSF Identify

1. Environment Overview

Microsoft Defender XDR (Extended Detection and Response) is Microsoft's unified security platform providing threat detection, investigation, and response across identities, endpoints, email, and cloud applications. For a GRC analyst, Defender is both a security tool and an evidence source - it generates the vulnerability reports, threat detections, and compliance data used to demonstrate control effectiveness during audits.

1.1 Defender Dashboard

The Defender home dashboard provides an at-a-glance security overview including active incidents, device health, threat analytics, and the Secure Score summary. This is the starting point for any security posture review.

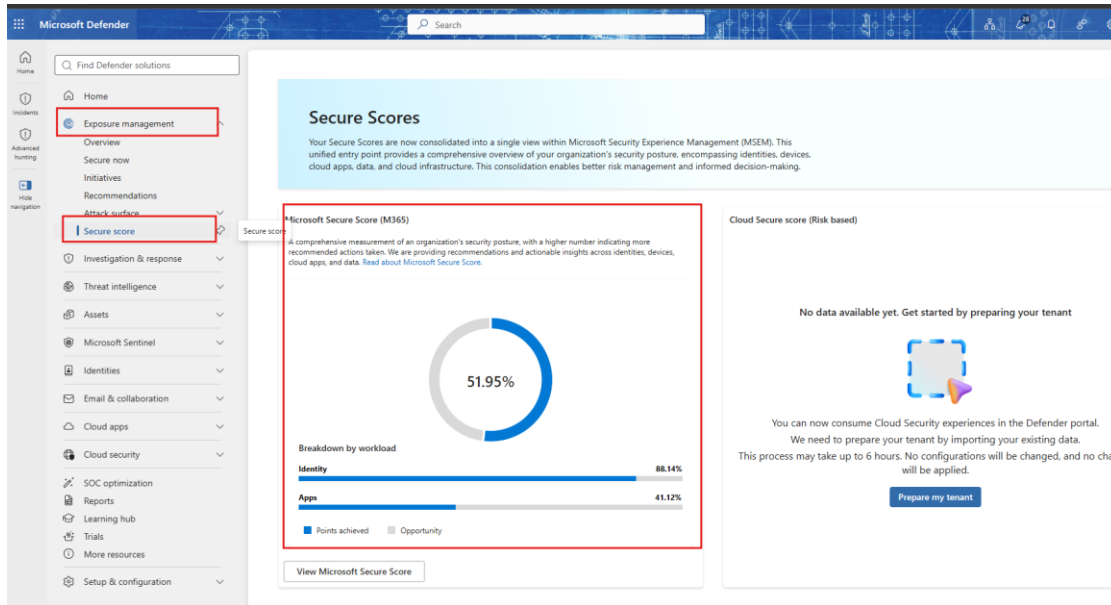


2. Secure Score Assessment

Microsoft Secure Score quantifies an organization's security posture as a numerical value - the higher the score, the stronger the security configuration. The score is calculated based on which recommended security actions have been implemented versus the total possible actions. It provides a measurable, trackable metric for security improvement over time - exactly the kind of evidence auditors and leadership need.

2.1 Baseline Score

The initial Secure Score was recorded as the baseline for this assessment. This represents the security posture before any improvement actions were taken during this assessment cycle.

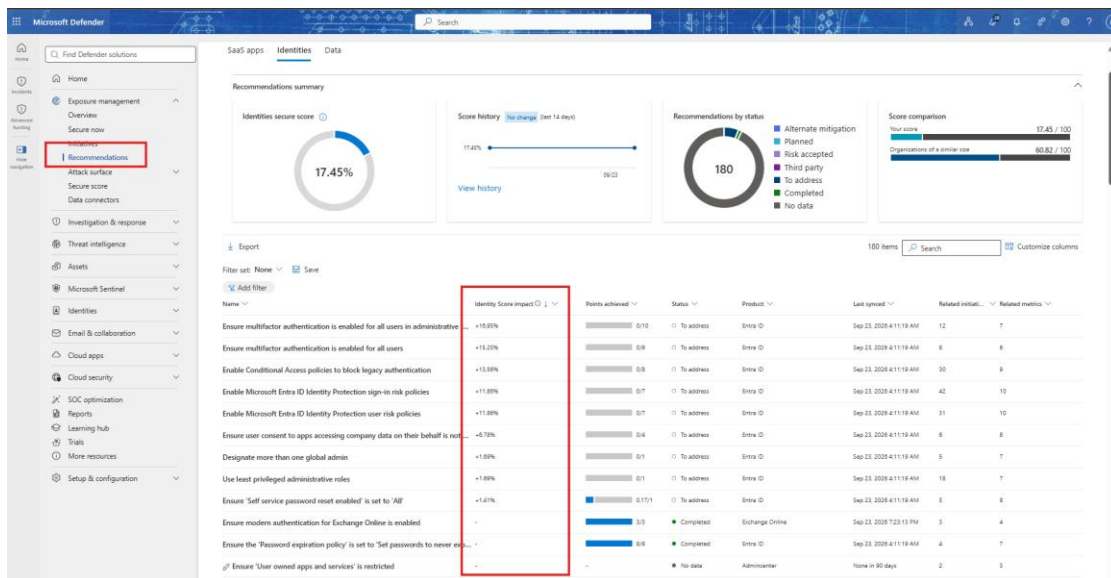


The Secure Score provides category-level breakdown (Identity, Device, Apps, Data) allowing targeted improvement in specific security domains. For GRC reporting, this breakdown enables department-specific or control-category-specific compliance tracking.

3. Recommended Actions - Prioritized by Impact

Secure Score provides a prioritized list of recommended security actions, each showing the potential score impact if implemented. This prioritization is critical for GRC - it enables risk-based decision making about where to invest remediation effort for maximum security improvement. Actions with the highest score impact address the most significant configuration gaps.

3.1 Top Recommended Actions (Sorted by Score Impact)

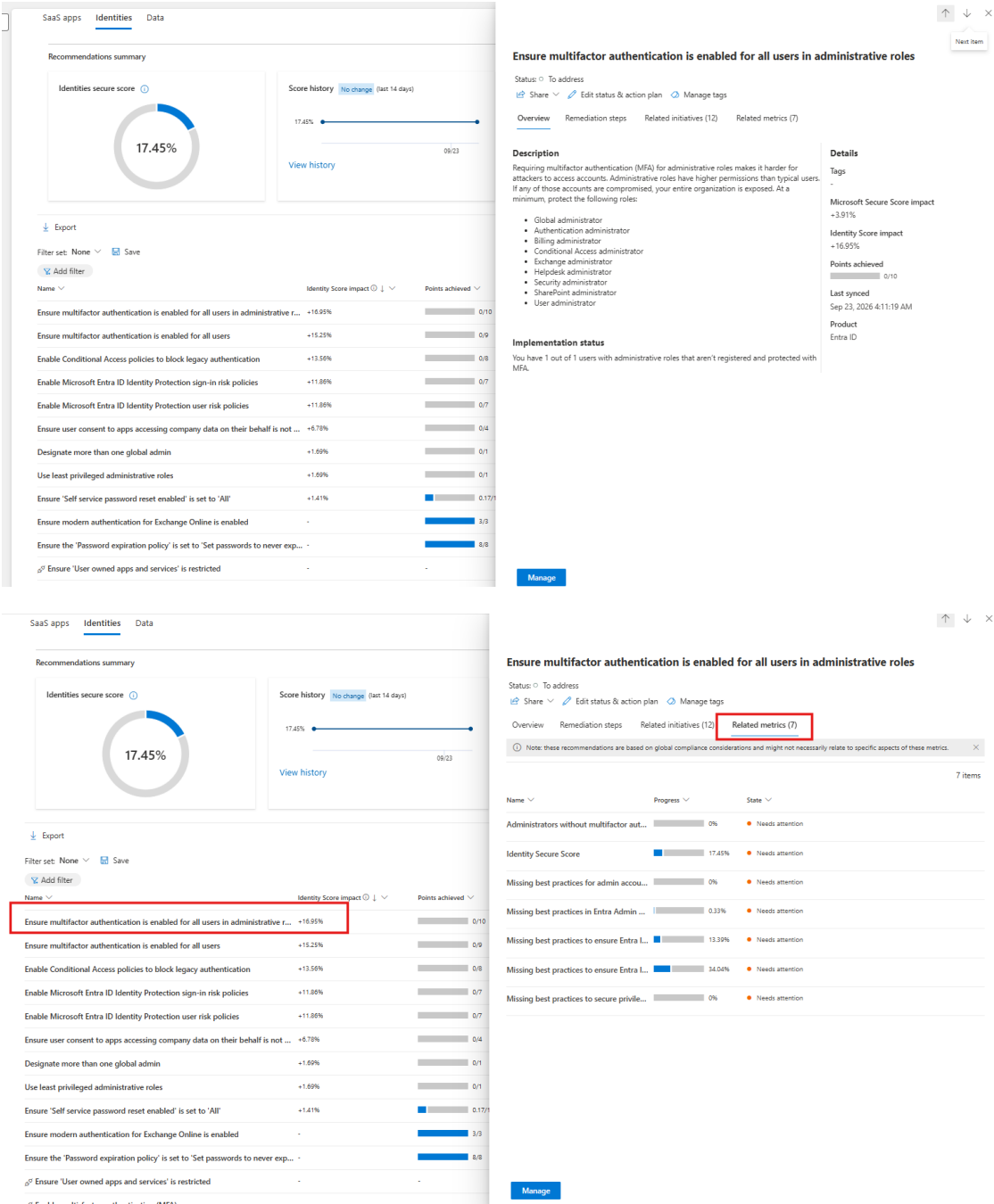


Sorting by score impact is the recommended approach for remediation prioritization. In a compliance context, this maps to risk-based vulnerability management - addressing the highest-impact gaps first, which is required by ISO 27001 A.8.8 and PCI DSS Requirement 6.1.

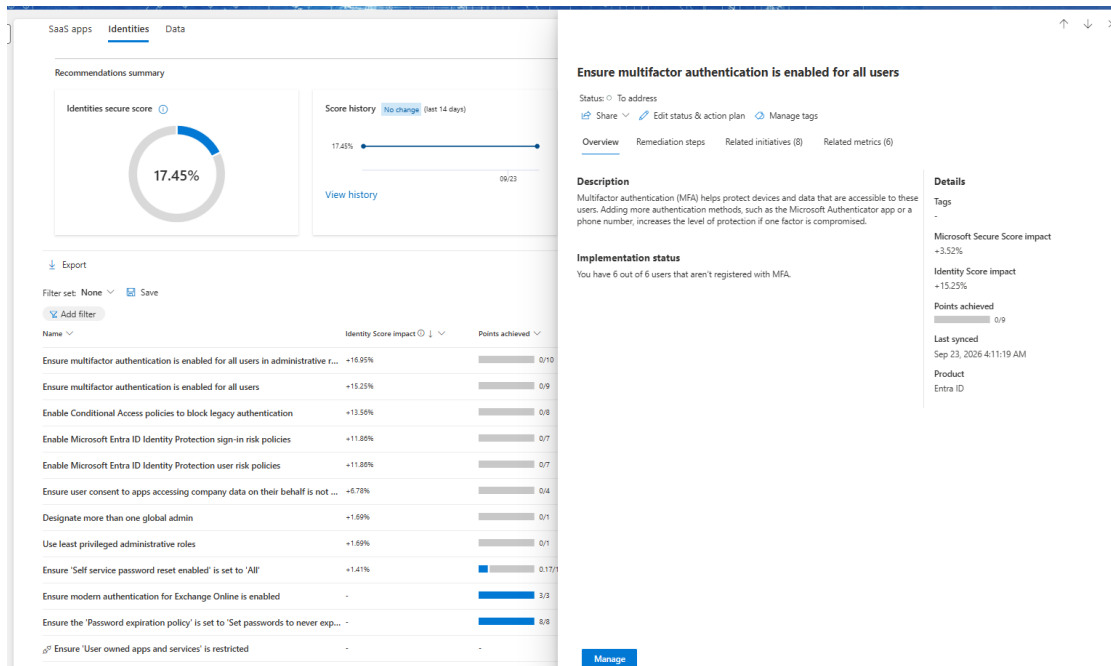
3.2 Top 3 Recommended Actions - Detailed Analysis

The top three recommended actions were expanded to understand the specific configuration changes required, the compliance frameworks they support, and the implementation complexity involved.

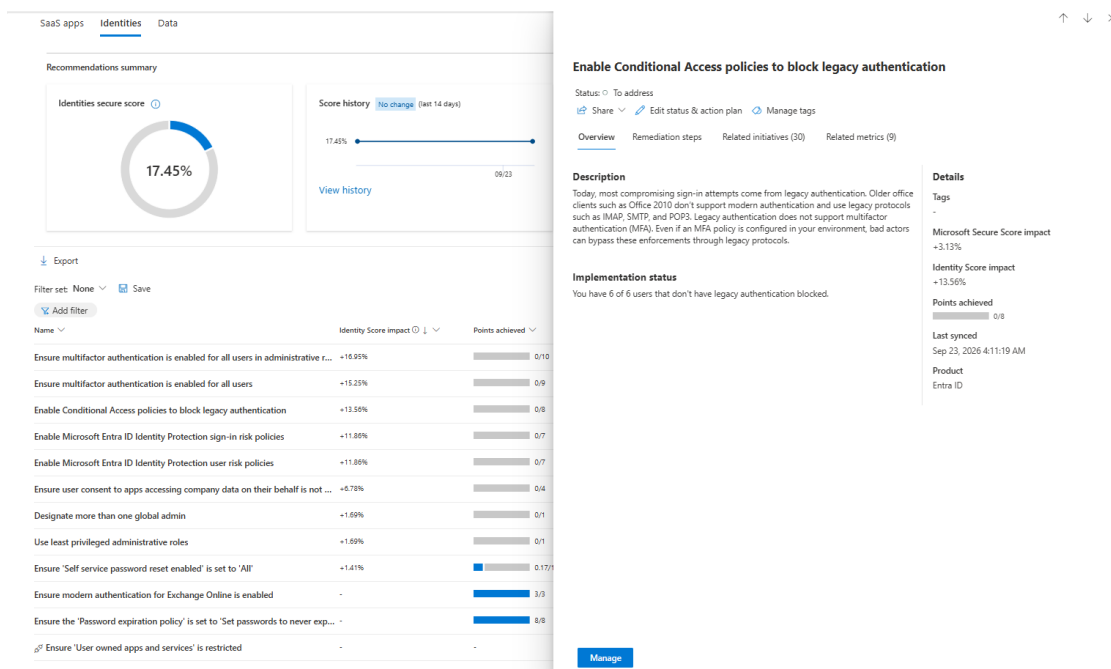
Recommendation 1



Recommendation 2



Recommendation 3



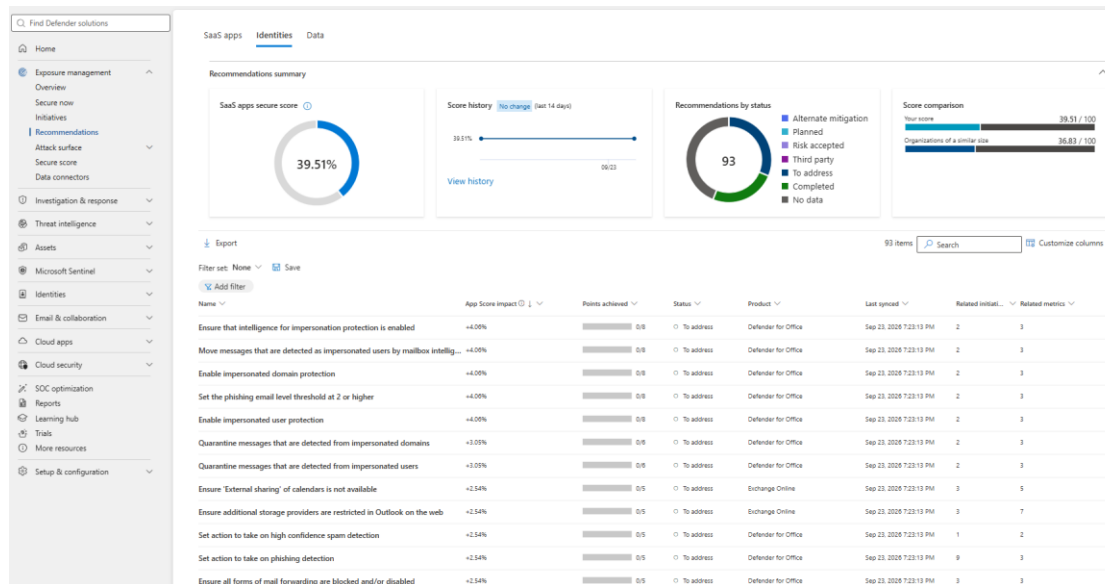
Each recommended action detail page shows implementation steps, affected users/devices, compliance framework mapping, and the specific score improvement. This level of detail enables a GRC analyst to build a remediation plan with clear business justification for each action.

4. Quick-Win Remediation - Before and After

Following the assessment, quick-win remediation actions were implemented to demonstrate the continuous improvement cycle. MFA was enabled for additional users, building on the Conditional Access policies created in Project 1 (Entra ID). The Secure Score was re-evaluated after implementation to measure the improvement.

4.1 Post-Remediation Score

After enabling MFA for 2 additional users, the Secure Score was rechecked. This before-and-after comparison demonstrates the measurable impact of security configuration changes - providing the kind of quantitative evidence that leadership and auditors need to see that security investments produce results.



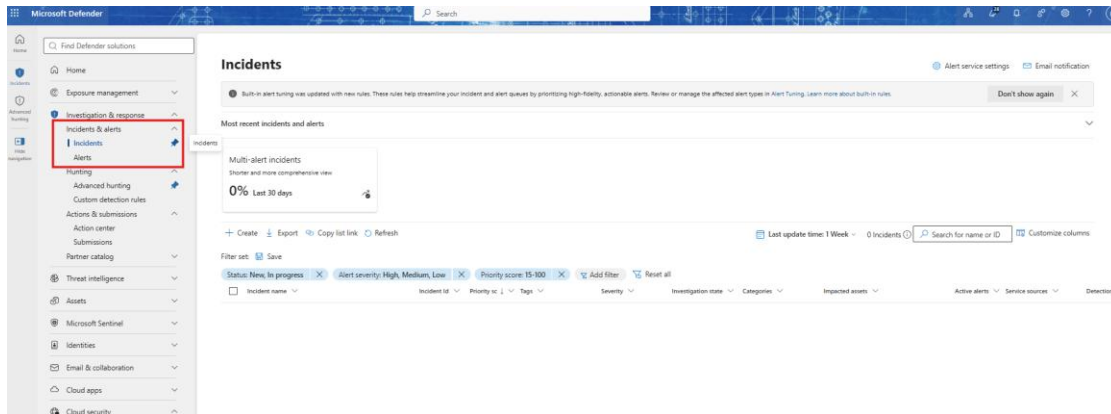
ISO 27001 Clause 10 requires continual improvement of the ISMS. The Secure Score before/after comparison is direct, measurable evidence of this improvement cycle in action. SOC 2 CC4.1 requires monitoring of controls for operating effectiveness - Secure Score tracking provides this continuously.

5. Security Monitoring - Incidents, Threats, and Reporting

Beyond Secure Score, Microsoft Defender provides continuous security monitoring capabilities. A GRC analyst uses these dashboards to verify that detective controls are functioning, to identify emerging threats that may require policy updates, and to generate compliance evidence for audit periods.

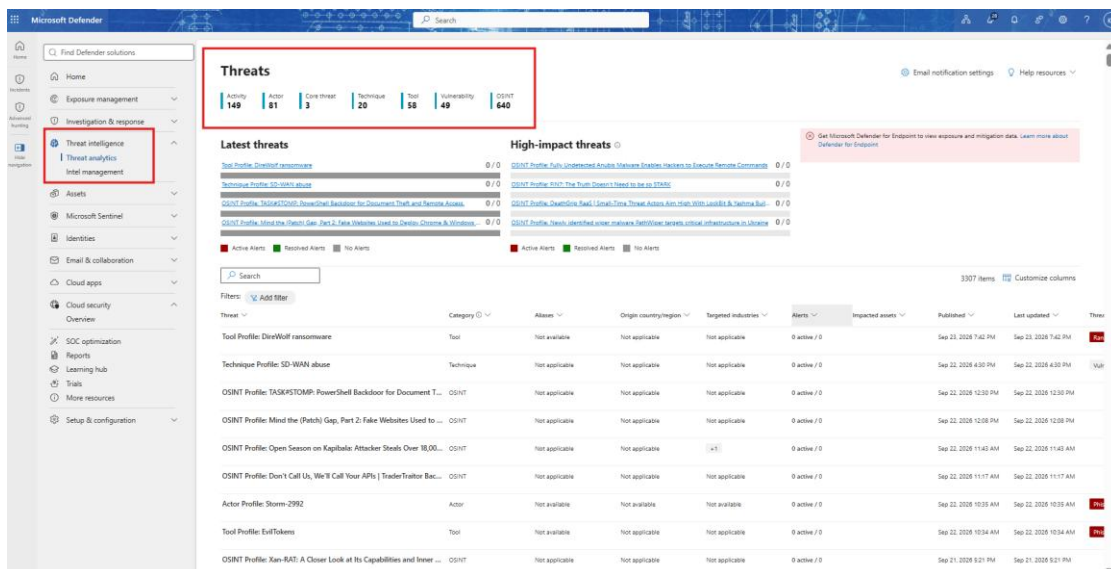
5.1 Incidents & Alerts

The Incidents dashboard shows security events detected across the environment - correlated from multiple signals (identity, endpoint, email, cloud apps) into unified incidents for investigation. Each incident includes severity, affected assets, investigation status, and remediation actions. This is the primary detective control evidence for SOC 2 CC7.2 (monitoring for anomalies) and ISO 27001 A.16.1.2 (reporting security events).



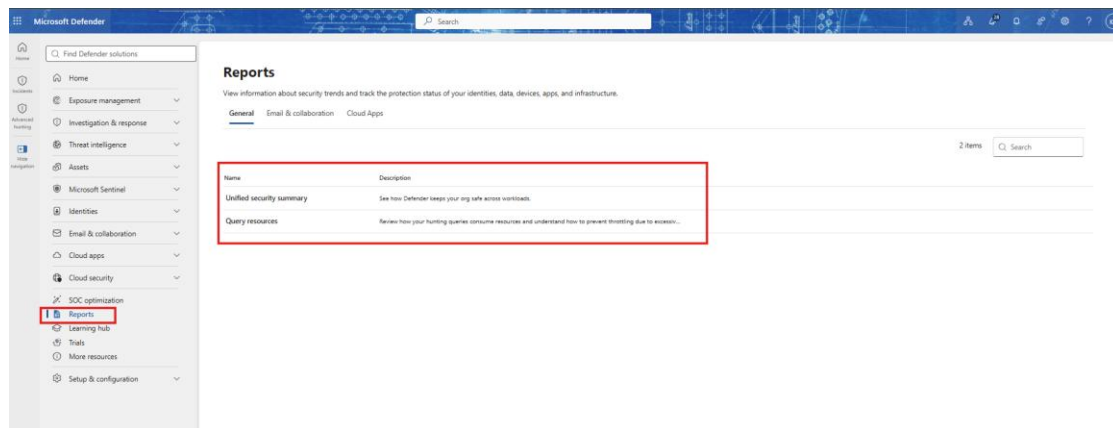
5.2 Threat Analytics

Threat Analytics provides intelligence on current threat campaigns relevant to the organization's environment - including active threat actors, attack techniques being used in the wild, and which of the organization's assets may be vulnerable to specific threats. This supports proactive risk management by connecting external threat intelligence to internal security posture, aligning with ISO 27001 A.5.7 (Threat Intelligence) and NIST CSF's Detect function.



5.3 Security Reports

Defender provides pre-built security reports covering device compliance, threat protection effectiveness, vulnerability trends, and more. These reports are the raw material for GRC compliance reporting - a compliance analyst would use these to build the dashboards and executive summaries that leadership and external auditors review during assessment periods.



PCI DSS Requirement 10 requires tracking and monitoring all access. NIST CSF Detect function requires continuous monitoring. These Defender dashboards provide the automated monitoring evidence that manual log review cannot scale to match.

6. Cross-Project Integration - Complete Security Architecture

This project completes the four-project Microsoft Security Portfolio. Together, the four projects form a complete enterprise security architecture:

Project 1 - Identity & Access Management (Entra ID): Controls WHO accesses the environment through users, groups, Conditional Access, MFA, and access reviews. Preventive controls.

Project 2 - Endpoint Compliance (Intune): Controls WHAT devices meet security standards through compliance policies, configuration profiles, and endpoint security. Preventive controls.

Project 3 - Data Classification & DLP (Purview): Controls WHAT data can go WHERE through sensitivity labels, auto-labeling, and DLP enforcement policies. Preventive and detective controls.

Project 4 - Security Posture Assessment (Defender): Measures HOW EFFECTIVE the controls are through Secure Score assessment, threat detection, incident monitoring, and continuous improvement tracking. Detective and corrective controls.

This progression from preventive controls (Projects 1-3) through detective and corrective controls (Project 4) mirrors the defense-in-depth model that ISO 27001, SOC 2, and NIST CSF all require. The Secure Score provides the measurable feedback loop that connects implementation to effectiveness - proving not just that controls exist (design effectiveness) but that they work (operating effectiveness).

7. Conclusion

This project demonstrates security posture assessment methodology using Microsoft Defender's Secure Score framework - from baseline measurement through prioritized recommendations, quick-win remediation, and measurable improvement tracking. The before-and-after score comparison provides concrete evidence of the continuous improvement cycle that ISO 27001 Clause 10 requires.

Combined with the three preceding projects, this completes a four-project Microsoft Security Portfolio covering the full spectrum of enterprise security controls: identity management, endpoint compliance, data protection, and security posture assessment. Each project maps to specific ISO 27001, SOC 2, PCI DSS, and NIST CSF requirements, demonstrating both technical implementation capability and compliance-mapping discipline.

The complete portfolio is available at <https://www.github.com/ethicalkaps/microsoft-security-portfolio>.